Explotación de Vulnerabilidades

Recordemos algunos conceptos

Amenaza



Una amenaza es cualquier evento o acción que puede causar daño a un activo, sistema o persona. Es algo que tiene el potencial de explotar una vulnerabilidad.

Riesgo



El riesgo es la probabilidad de que una amenaza explote una vulnerabilidad y cause daño, combinado con la severidad del impacto.

Vulnerabilidad



Es una debilidad interna que puede ser explotada por una amenaza. Es la falla, la grieta, la puerta mal cerrada que facilita que el peligro se materialice.

Otros más

Es justamente la vulnerabilidad lo que aprovechamos para “hackear”.

Si no hay vulnerabilidad, no hay riesgo (R = A x V)

Exploit



Es el código construido específicamente para aprovechar esa vulnerabilidad

Payload (carga útil)



Es el código “malicioso” en sí mismo, lo que sucede después de aprovechar la vulnerabilidad

Proceso de Hacking (Ético)

Es el siguiente paso a dar

1. Reconocimiento

Investigación, recopilación de información

Ejemplos
(OSINT, preparación de máquinas)

2. Escaneo

A sus sistemas, redes, puertos, usuarios, vulnerabilidades

Ejemplos
(nmap, nessus, openvas)

3. Explotación

Generalmente la infiltración al sistema

Ejemplos
(uso de exploit, correos o páginas web más hechas)

Proceso de Hacking (Ético)

Es el siguiente paso a dar

4.



Post-explotación/persistencia

Seguimos explotando la vulnerabilidad a la vez que nos mantenemos ocultos

Ejemplos
(backdoors, anonimato, conexión)

5.



Acción

(Uso de ransomware, robo de datos, bloqueo de sistemas.)

Práctica VI

https://tryhackme.com/room/monikerlink

Preparación

Al ser un ambiente controlado es necesario preparar el escenario: spawnear máquinas virtuales, configurar redes, controles, usuarios, etc.



En este caso será la VPN



Y la máquina virtual objetivo

Escaneo

Resultados del análisis con Nmap para identificar servicios y versiones.

Objetivo del Escaneo

Enumerar servicios activos y sus versiones para investigar posibles vulnerabilidades conocidas.



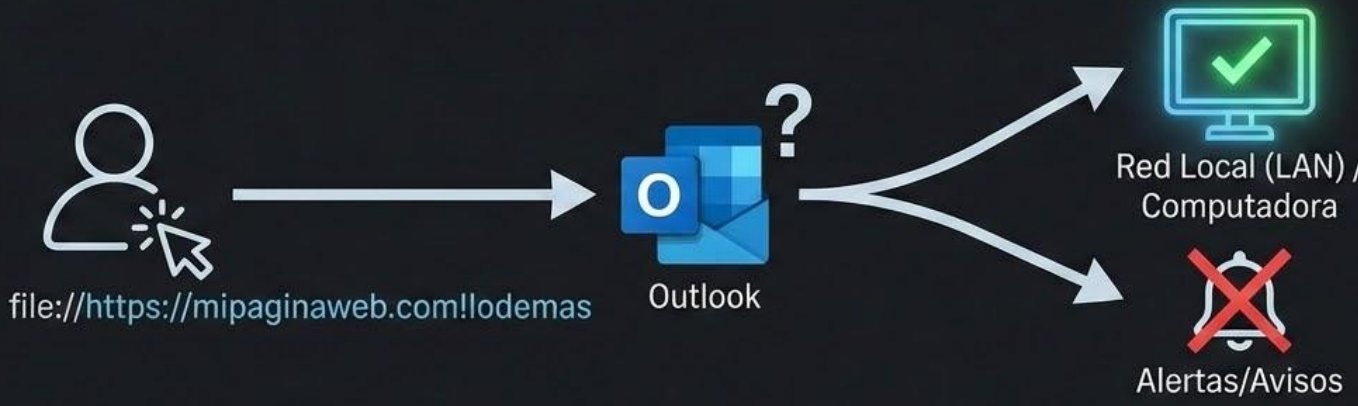
Escaneo (Investigación: CVE-2024-21413)

Los resultados arrojan que se trata de un bypass en la vista protegida de un correo al momento de seguir un enlace



CVE-2024-21413

¿Cómo funciona?



- En lugar de una dirección normal (https://mipaginaweb.com), la alteramos con **file://...**
- Esto hace creer a Outlook que es un recurso local confiable
- Por lo tanto, no se activan alertas ni avisos
- Esto es la vulnerabilidad

Buscamos exploit

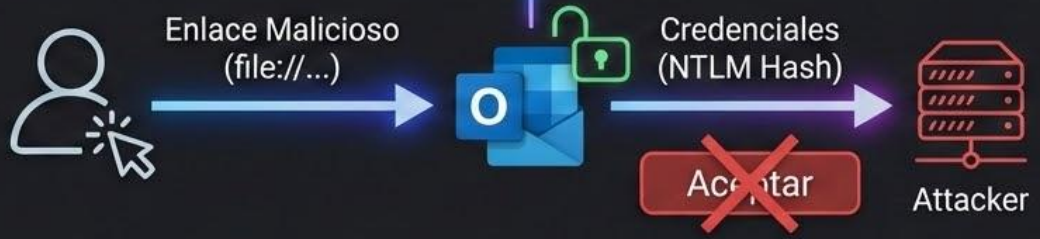
Objetivo: Comprometer Credenciales de Outlook

Tipos de Exploit Comunes

- Ganar Acceso
- Consola Remota (Reverse Shell)
- Robar Datos
- Propagar Virus

El Caso Específico: Vista Protegida de Outlook

En este caso, "tomaremos prestadas" las credenciales del usuario (guiño guiño). Outlook envía la contraseña al dar "Aceptar". Queremos que la envíe al hacer clic en el enlace, sin "Aceptar".



El exploit evita el paso de confirmación manual, enviando automáticamente las credenciales.

Exploit

CVE-2024-21413: Microsoft Outlook Remote Code Execution Vulnerability

https://github.com/CMNatic/CVE-2024-21413

1. Configurar Servidor de Credenciales



Levantar un servidor local para recibir las credenciales capturadas.

2. Modificar el Script del Exploit



Actualizar el script con los correos electrónicos y la IP del atacante (IP de VPN).

Captura de Credenciales



1. Ejecutar el Script

Ejecutamos el script configurado anteriormente.



2. Interacción de la Víctima

La víctima hace clic en el enlace malicioso.



3. Recepción de Hashes

Los hashes de credenciales se envían al servidor atacante.

⚠ **NOTA IMPORTANTE:** Esto solo funciona si la víctima hace clic en el enlace.